

Application vulnerabilities can be present for many reasons: insecure design, insecure infrastructure, coding mistakes, weak authentication, and failure to test for unusual or unexpected conditions. Attackers can exploit specific vulnerabilities, including buffer overflows, exposure to Structured Query Language (SQL) injection, cross-site scripting, cross-site request forgery, and click-jacking of code to gain access to sensitive data, or take control over vulnerable assets within the infrastructure as a launching point for further attacks.

Applications and websites can also be used to harvest credentials, data, or attempt to install malware onto the users who access them.

Finally, it is now more common to acquire Software as a Service (SaaS) platforms, where software is developed and managed entirely through a third-party. These might be hosted anywhere in the world. This brings challenges to enterprises that need to know what risks they are accepting with using these platforms; and, they often do not have visibility into the development and application security practices of these platforms. Some of these SaaS platforms allow for customizing of their interfaces and databases. Enterprises that extend these applications should follow this CIS Control, similar to if they were doing ground-up customer development.

Procedures and tools

For Version 8, CIS partnered with SAFECode to help develop the procedures and Safeguards for this updated Application Software Security Control. However, application software security is a large topic on its own, and so (consistent with the principles of the overall CIS Controls), we focus here on the most critical Safeguards. These were derived from a companion paper on application software security that SAFECode developed (referenced below), which provides a more in-depth treatment of the topic, and is consistent with SAFECode's existing body of content.

SAFECode developed a three-tiered approach to help readers identify which Development Group (DG) they fit in as a maturity scale for development programs. The three CIS IG levels used within the Safeguards inspired their approach for the DGs below:

Development Group 1

The enterprise largely relies on off-the-shelf or Open Source Software (OSS) and packages with only the occasional addition of small applications or website coding. The enterprise is capable of applying basic operational and procedural best practices and of managing the security of its vendor-supplied software as a result of following the guidance of the CIS Controls.

Development Group 2

The enterprise relies on some custom (in-house or contractor-developed) web and/or native code applications integrated with third-party components and runs on-premises or in the cloud. The enterprise has a development staff that applies software development best practices. The enterprise is attentive to the quality and maintenance of third-party open source or commercial code on which it depends.

Development Group 3

The enterprise makes a major investment in custom software that it requires to run its business and serve its customers. It may host software on its own infrastructure, in the cloud, or both, and may integrate a large range of third-party open source and commercial software components. Software vendors and enterprises that deliver SaaS should consider Development Group 3 as a minimum set of requirements.

The first step in developing an application security program is implementing a vulnerability management process. This process must integrate into the development life cycle, and should be lightweight to insert into the standard bug-fixing progress. The process should include root cause analysis to fix underlying flaws so as to reduce future vulnerabilities, and a severity rating to prioritize remediation efforts.

Developers need to be trained in application security concepts and secure coding practices. This includes a process to acquire or evaluate third-party software, modules, and libraries used in the application to ensure they do not introduce security flaws. The developers should be taught what types of modules they can securely use, where they can be safely acquired, and which components they can, or should not, develop themselves (e.g., encryption).

Weaknesses in the infrastructure that supports these applications can introduce risk. The CIS Controls and the concept of minimizing the attack surface can help secure networks, systems, and accounts that are used within the application. Specific guidance can be found in CIS Controls 1-7, 12, and 13.

The ideal application security program is one that introduces security as early into the software development life cycle as possible. The management of security problems should be consistent and integrated with standard software flaw/bug management, as opposed to a separate process that competes for development resources. Larger or more mature development teams should consider the practice of threat modeling in the design phase. Design-level vulnerabilities are less common than code-level vulnerabilities; however, they often are very severe and much harder to fix quickly. Threat modeling is the process of identifying and addressing application security design flaws before code is created. Threat modeling requires specific training, technical, and business knowledge. It is best conducted through internal “security champions” in each development team, to lead threat modeling practices for that team’s software. It also provides valuable context to downstream activities, such as root cause analysis and security testing.

Larger, or commercial, development teams may also consider a bug bounty program where individuals are paid for finding flaws in their applications. Such a program is best used to supplement an in-house secure development process and can provide an efficient mechanism for identifying classes of vulnerabilities that the process needs to focus on.

Finally, in 2020 NIST® published its Secure Software Development Framework (SSDF), which brought together what the industry has learned about software security over the past two decades and created a secure software development framework for planning, evaluating, and communicating about software security activities. Enterprises acquiring software or services can use this framework to build their security requirements and understand whether a software provider’s development process follows best practices. These are some application security resources:

SAFECode Application Security Addendum: <https://safecode.org/cis-controls/>

NIST® SSDF: <https://csrc.nist.gov/News/2020/mitigating-risk-of-software-vulns-ssdf>

The Software Alliance: <https://www.bsa.org/reports/updated-bsa-framework-for-secure-software>

OWASP®: <https://owasp.org/>

Safeguards

Safeguard 16.1: Establish and Maintain a Secure Application Development Process

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Establish and maintain a secure application development process. In the process, address such items as: secure application design standards, secure coding practices, developer training, vulnerability management, security of third-party code, and application security testing procedures. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 16.2: Establish and Maintain a Process to Accept and Address Software Vulnerabilities

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Establish and maintain a process to accept and address reports of software vulnerabilities, including providing a means for external entities to report. The process is to include such items as: a vulnerability handling policy that identifies reporting process, responsible party for handling vulnerability reports, and a process for intake, assignment, remediation, and remediation testing. As part of the process, use a vulnerability tracking system that includes severity ratings and metrics for measuring timing for identification, analysis, and remediation of vulnerabilities. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Third-party application developers need to consider this an externally-facing policy that helps to set expectations for outside stakeholders.

Safeguard 16.3: Perform Root Cause Analysis on Security Vulnerabilities

Asset Type: Software	Security Function: Detect	IG2	IG3
----------------------	---------------------------	-----	-----

Perform root cause analysis on security vulnerabilities. When reviewing vulnerabilities, root cause analysis is the task of evaluating underlying issues that create vulnerabilities in code, and allows development teams to move beyond just fixing individual vulnerabilities as they arise.

Safeguard 16.4: Establish and Manage an Inventory of Third-Party Software Components

Asset Type: Software	Security Function: Identify	IG2	IG3
-----------------------------	------------------------------------	------------	------------

Establish and manage an updated inventory of third-party components used in development, often referred to as a “bill of materials,” as well as components slated for future use. This inventory is to include any risks that each third-party component could pose. Evaluate the list at least monthly to identify any changes or updates to these components, and validate that the component is still supported.

Safeguard 16.5: Use Up-to-Date and Trusted Third-Party Software Components

Asset Type: Software	Security Function: Protect	IG2	IG3
-----------------------------	-----------------------------------	------------	------------

Use up-to-date and trusted third-party software components. When possible, choose established and proven frameworks and libraries that provide adequate security. Acquire these components from trusted sources or evaluate the software for vulnerabilities before use.

Safeguard 16.6: Establish and Maintain a Severity Rating System and Process for Application Vulnerabilities

Asset Type: Documentation	Security Function: Govern	IG2	IG3
----------------------------------	----------------------------------	------------	------------

Establish and maintain a severity rating system and process for application vulnerabilities that facilitates prioritizing the order in which discovered vulnerabilities are fixed. This process includes setting a minimum level of security acceptability for releasing code or applications. Severity ratings bring a systematic way of triaging vulnerabilities that improves risk management and helps ensure the most severe bugs are fixed first. Review and update the system and process annually.

Safeguard 16.7: Use Standard Hardening Configuration Templates for Application Infrastructure

Asset Type: Software	Security Function: Protect	IG2	IG3
-----------------------------	-----------------------------------	------------	------------

Use standard, industry-recommended hardening configuration templates for application infrastructure components. This includes underlying servers, databases, and web servers, and applies to cloud containers, Platform as a Service (PaaS) components, and SaaS components. Do not allow in-house developed software to weaken configuration hardening.

Safeguard 16.8: Separate Production and Non-Production Systems

Asset Type: Network	Security Function: Protect	IG2	IG3
---------------------	----------------------------	-----	-----

Maintain separate environments for production and non-production systems.

Safeguard 16.9: Train Developers in Application Security Concepts and Secure Coding

Asset Type: Users	Security Function: Protect	IG2	IG3
-------------------	----------------------------	-----	-----

Ensure that all software development personnel receive training in writing secure code for their specific development environment and responsibilities. Training can include general security principles and application security standard practices. Conduct training at least annually and design in a way to promote security within the development team, and build a culture of security among the developers.

Safeguard 16.10: Apply Secure Design Principles in Application Architectures

Asset Type: Software	Security Function: Protect	IG2	IG3
----------------------	----------------------------	-----	-----

Apply secure design principles in application architectures. Secure design principles include the concept of least privilege and enforcing mediation to validate every operation that the user makes, promoting the concept of “never trust user input.” Examples include ensuring that explicit error checking is performed and documented for all input, including for size, data type, and acceptable ranges or formats. Secure design also means minimizing the application infrastructure attack surface, such as turning off unprotected ports and services, removing unnecessary programs and files, and renaming or removing default accounts.

Safeguard 16.11: Leverage Vetted Modules or Services for Application Security Components

Asset Type: Software	Security Function: Protect	IG2	IG3
----------------------	----------------------------	-----	-----

Leverage vetted modules or services for application security components, such as identity management, encryption, auditing, and logging. Using platform features in critical security functions will reduce developers’ workload and minimize the likelihood of design or implementation errors. Modern operating systems provide effective mechanisms for identification, authentication, and authorization and make those mechanisms available to applications. Use only standardized, currently accepted, and extensively reviewed encryption algorithms. Operating systems also provide mechanisms to create and maintain secure audit logs.

Safeguard 16.12: Implement Code-Level Security Checks

Asset Type: Software	Security Function: Protect	IG3
----------------------	----------------------------	-----

Apply static and dynamic analysis tools within the application life cycle to verify that secure coding practices are being followed.

Safeguard 16.13: Conduct Application Penetration Testing

Asset Type: Software	Security Function: Detect	IG3
----------------------	---------------------------	-----

Conduct application penetration testing. For critical applications, authenticated penetration testing is better suited to finding business logic vulnerabilities than code scanning and automated security testing. Penetration testing relies on the skill of the tester to manually manipulate an application as an authenticated and unauthenticated user.

Safeguard 16.14: Conduct Threat Modeling

Asset Type: Software	Security Function: Protect	IG3
----------------------	----------------------------	-----

Conduct threat modeling. Threat modeling is the process of identifying and addressing application security design flaws within a design, before code is created. It is conducted through specially trained individuals who evaluate the application design and gauge security risks for each entry point and access level. The goal is to map out the application, architecture, and infrastructure in a structured way to understand its weaknesses.

CONTROL 17

Incident Response Management

Safeguards: 9	IG1: 3/9	IG2: 8/9	IG3: 9/9
---------------	----------	----------	----------

Overview

Establish a program to develop and maintain an incident response capability (e.g., policies, plans, procedures, defined roles, training, and communications) to prepare, detect, and quickly respond to an attack.

Why is this Control critical?

A comprehensive cybersecurity program includes protections, detections, response, and recovery capabilities. Often, the final two get overlooked in immature enterprises, or the response technique to compromised systems is just to re-image them to original state, and move on. The primary goal of incident response is to identify threats on the enterprise, respond to them before they can spread, and remediate them before they can cause harm. Without understanding the full scope of an incident, how it happened, and what can be done to prevent it from happening again, defenders will just be in a perpetual “whack-a-mole” pattern.

We cannot expect our protections to be effective 100% of the time. When an incident occurs, if an enterprise does not have a documented plan—even with good people—it is almost impossible to know the right investigative procedures, reporting, data collection, management responsibility, legal protocols, and communications strategy that will allow the enterprise to successfully understand, manage, and recover.

Along with detection, containment, and eradication, communication to stakeholders is key. If we are to reduce the probability of material impact due to a cyber event, the enterprise’s leadership must know what potential impact there could be, so that they can help prioritize remediation or restoration decisions that best support the enterprise. These business decisions could be based on regulatory compliance, disclosure rules, service-level agreements with partners or customers, revenue, or mission impacts.

Dwell time from when an attack happens to when it is identified can be days, weeks, or months. The longer the attacker is in the enterprise’s infrastructure, the more embedded they become and they will develop more ways to maintain persistent access for when they are eventually discovered. With the rise of ransomware, which is a stable moneymaker for attackers, this dwell time is critical, especially with modern tactics of stealing data before encrypting it for ransom.

Procedures and tools

Even if an enterprise does not have resources to conduct incident response within an enterprise, it is still critical to have a documented plan. This would include the sources for protections and detections, a list of who to call upon for assistance, and communication plans about how to convey information to leadership, employees, regulators, partners, and customers.

After defining incident response procedures, the incident response team, or a third-party, should engage in periodic scenario-based training, working through a series of attack scenarios fine-tuned to the threats and potential impacts the enterprise faces. These scenarios help ensure that enterprise leadership and technical team members understand their role in the incident response process to help prepare them to handle incidents. It is inevitable that exercise and training scenarios will identify gaps in plans and processes, and unexpected dependencies, which can then be updated into the plan.

More mature enterprises should include threat intelligence and/or threat hunting into their incident response process. This will help the team become more proactive, identifying key or primary attackers to their enterprise or industry to monitor or search for their TTPs. This will help focus detections and define response procedures to identify and remediate more quickly.

The actions in CIS Control 17 provide specific, high-priority steps that can improve enterprise security, and should be a part of any comprehensive incident response plan. In addition, we recommend the following resource dedicated to this topic:

Council of Registered Security Testers (CREST) Cyber Security Incident Response Guide:
CREST provides guidance, standards, and knowledge on a wide variety of cyber defense topics.
<https://www.crest-approved.org/wp-content/uploads/2022/04/CSIR-Procurement-Guide-1.pdf>

Safeguards

Safeguard 17.1: Designate Personnel to Manage Incident Handling

Asset Type: Users	Security Function: Respond	IG1	IG2	IG3
--------------------------	-----------------------------------	------------	------------	------------

Designate one key person, and at least one backup, who will manage the enterprise’s incident handling process. Management personnel are responsible for the coordination and documentation of incident response and recovery efforts and can consist of employees internal to the enterprise, service providers, or a hybrid approach. If using a service provider, designate at least one person internal to the enterprise to oversee any third-party work. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.2: Establish and Maintain Contact Information for Reporting Security Incidents

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain contact information for parties that need to be informed of security incidents. Contacts may include internal staff, service providers, law enforcement, cyber insurance providers, relevant government agencies, Information Sharing and Analysis Center (ISAC) partners, or other stakeholders. Verify contacts annually to ensure that information is up-to-date.

Safeguard 17.3: Establish and Maintain an Enterprise Process for Reporting Incidents

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain an documented enterprise process for the workforce to report security incidents. The process includes reporting timeframe, personnel to report to, mechanism for reporting, and the minimum information to be reported. Ensure the process is publicly available to all of the workforce. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.4: Establish and Maintain an Incident Response Process

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Establish and maintain a documented incident response process that addresses roles and responsibilities, compliance requirements, and a communication plan. Review annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 17.5: Assign Key Roles and Responsibilities

Asset Type: Users	Security Function: Respond	IG2	IG3
-------------------	----------------------------	-----	-----

Assign key roles and responsibilities for incident response, including staff from legal, IT, information security, facilities, public relations, human resources, incident responders, analysts, and relevant third parties. Review annually, or when significant enterprise changes occur that could impact this Safeguard.